

Beleidskader Informatiebeveiliging: Integratie van AVG, NEN 7510 en NEN 7513 in de Zorg

1. Strategische Context en Doelstelling

In de hedendaagse gedigitaliseerde zorgomgeving is informatiebeveiliging geen louter ICT-vraagstuk meer, maar een fundamentele pijler van "goed hulpverlenerschap" en patiëntveiligheid. De kwetsbaarheid van medische data is evident; een datalek of systeemuitval tast direct de persoonlijke integriteit van de cliënt aan en brengt de continuïteit van zorg in gevaar. Als Strategisch Adviseur stel ik dat het vinden van de balans tussen databeschikbaarheid voor de behandelaar en de bescherming van de levenssfeer van de patiënt de kern vormt van ons risicomanagement. Dit beleidskader vertaalt de abstracte beveiligingsplicht van Artikel 32 AVG naar de concrete normatieve kaders van NEN 7510 en NEN 7513. Het fundament van dit kader rust op de BIV-classificatie:

- **Beschikbaarheid:** Het waarborgen dat vitale patiëntinformatie op het moment van behandeling onmiddellijk toegankelijk is. Uitval leidt tot uitgestelde operaties en gesloten spoedeisende hulp.
- **Integriteit:** Het garanderen dat medische gegevens juist en ongewijzigd blijven. Incomplete of foutieve data leiden onvermijdelijk tot medische missers.
- **Vertrouwelijkheid:** Het beperken van toegang tot uitsluitend die personen die een directe behandelrelatie hebben, ter voorkoming van identiteitsfraude en onherstelbare reputatieschade. Deze classificatie vormt de basis voor de synergie tussen privacywetgeving en zorgspecifieke kaders.

2. Juridisch Fundament: De Synergie tussen AVG en WGBO

De rechtmatigheid van onze gegevensverwerking wordt bepaald door de wisselwerking tussen de AVG (het algemene kader) en de WGBO (de sectorspecifieke wet). De WGBO normeert het medisch beroepsgeheim, terwijl de AVG de randvoorwaarden voor de verwerking van persoonsgegevens stelt. Een essentieel strategisch inzicht betreft de contextafhankelijkheid van medische data. Conform het huidige beleid van de Autoriteit Persoonsgegevens (AP) is niet elk beeld waarop een patiënt herkenbaar is (bijv. in een rolstoel op algemene beveiligingscamera's) direct een 'bijzonder persoonsgegeven'. De intentie van de verwerking is bepalend: is de registratie gericht op het vastleggen van gezondheidsdata, of is dit een onvermijdelijk bijeffect van algemene beveiliging? Zodra beelden echter in een zorgcontext worden geplaatst, geldt het strikte regime van Artikel 9 AVG. | Aspect | Zorggerelateerde verwerking | Secundaire verwerking (Marketing/Sfeer) || ----- | ----- | ----- || **Primaire Grondslag** | Behandelovereenkomst (WGBO) | Expliciete toestemming (AVG) || **Doel** | Diagnostiek, observatie en therapie | Nieuwsbrief, website, social media || **Bewaartermijn** | Minimaal 20 jaar (WGBO) | Niet langer dan noodzakelijk voor het doel || **Toegang** | Direct betrokken behandelaars | Communicatie- of marketingafdeling |

Conclusie: Strikte doelbinding is de enige weg om juridische aansprakelijkheid te voorkomen. Technical safeguards moeten dit juridische kader dwingend ondersteunen.

3. Vertaling van AVG Artikel 32 naar NEN-standaarden

De AP hanteert de normen NEN 7510 en NEN 7513 als dé maatstaf voor 'passende maatregelen'. Voor de Raad van Bestuur betekent dit dat naleving van deze normen de enige manier is om aan te tonen dat de organisatie 'in control' is.

Toegangsbeveiliging en Authenticatie

Multi-Factor Authenticatie (MFA) is de ononderhandelbare professionele standaard. Het enkel gebruiken van een wachtwoord of personeelspas wordt door de AP en de rechter inmiddels gekwalificeerd als grove nalatigheid. Een cruciale les uit de HagaZiekenhuis-casus: de oorspronkelijke boete van €460.000,- werd door de rechter verlaagd naar €350.000,- omdat het ziekenhuis direct na de inbreuk substantiële verbetermaatregelen trof. Strategisch gezien loont proactieve verbetering dus direct in het mitigeren van boeterisico's.

Logging conform NEN 7513

Logging is de "flight recorder" van het zorgproces. Conform NEN 7513 moet de logging voldoen aan:

1. **Onweerlegbaarheid:** De koppeling tussen een unieke gebruikersidentiteit, de handeling en de exacte tijdstempel moet onomstotelijk zijn.
2. **Traceerbaarheid:** De logging moet een volledige reconstructie van de gebeurtenissen in een dossier mogelijk maken.
3. **Proactieve controle:** Passieve controle na klachten is onvoldoende. De norm vereist structurele, steekproefsgewijze analyses om onbevoegde inzage tijdig te detecteren.

4. Patiëntenrechten en Vertegenwoordiging bij Wilsonbekwaamheid

Bij kwetsbare groepen rust op ons de morele plicht tot extra zorgvuldigheid.

Wilsonbekwaamheid is nooit een algemene status, maar moet per situatie ("ter zake") door een arts worden beoordeeld.

Wettelijke Hiërarchie van Vertegenwoordiging (WGBO)

Indien een cliënt wilsonbekwaam is, geldt de volgende dwingende rangorde: | Rangorde | Type Vertegenwoordiger | Cruciale Bevoegdheid & Beperking || ----- | ----- | ----- || **1** | Curator of Mentor | De mentor beslist over persoonlijke/medische zaken. || **2** | Schriftelijk Gemachtigde | Bevoegd conform de specifieke volmacht. || **3** | Echtgenoot / Partner | Treedt op bij afwezigheid van rang 1 en 2. || **4** | Directe familieleden | Ouders, kinderen, broers/zussen. |

FG-WAARSCHUWING: Een **Bewindvoerder** is uitsluitend benoemd voor financiële belangen en is **geen** geldige vertegenwoordiger voor medische besluitvorming of privacy-toestemming, tenzij deze persoon tevens een van bovenstaande rollen vervult. **Veto-recht:** Het verzet van een (wilsonbekwame) cliënt weegt altijd zwaarder dan de toestemming van de vertegenwoordiger. Informed consent voor beeldmateriaal moet altijd vrijwillig, specifiek, geïnformeerd en herroepbaar zijn.

5. Beheer van Beeldmateriaal en Sociale Media

In een tijd van 'sharenting' moeten wij waken voor professionele vervaging. Er is een kritiek onderscheid tussen de 'huishoudelijke uitzondering' van de AVG (familie die onderling foto's deelt) en de professionele verantwoordelijkheid van de zorginstelling. Zodra onze organisatie of een vrijwilliger beelden maakt voor publicatie, vervalt elke uitzondering. **Richtlijnen voor Sociale Media:**

- **Identificeerbaarheid:** Denk breder dan het gezicht; ook rugaanzichten of unieke tatoeages maken iemand identificeerbaar.
- **Intrekking:** Intrekken van toestemming moet technisch net zo makkelijk zijn als het geven ervan.
- **Risico's:** Onrechtmatige publicatie stelt cliënten bloot aan misbruik (deepfakes). In Frankrijk wordt voor schending van privacy via beeldmateriaal zelfs een boete van €45.000,- gehanteerd; dit illustreert de internationale ernst van deze overtreding.

6. De Menselijke Factor: Vrijwilligers en BYOD-beperkingen

Vrijwilligers vallen onder het gezag van de zorginstelling; wij zijn als organisatie integraal aansprakelijk voor hun handelen.

Uitbanning van BYOD via Technische Isolatie

Het gebruik van privét toestellen (Bring Your Own Device) voor cliëntgegevens is strikt verboden vanwege ongecontroleerde cloud-synchronisatie (iCloud/Google Photos). Voor toegestane mobiele toepassingen geldt:

- **In-Memory Capturing:** Beelden worden in het vluchtige werkgeheugen (RAM) geladen en direct naar de beveiligde server gestuurd. Ze worden nooit weggeschreven naar de non-volatile lokale opslag (filmrol).
- **Sandbox-isolatie:** Apps moeten in een afgeschermd container draaien. Op Android moet de **FLAG_SECURE** parameter worden afgedwongen om screenshots en schermopnames technisch te blokkeren. **Contractuele waarborgen:** Vrijwilligers tekenen altijd een 'Geheimhoudingsverklaring' en 'Gedragscode Digitale Media'. Let op: boeteclausules voor AVG-overtredingen bij ondergeschikten zijn niet toegestaan, maar grove nalatigheid leidt tot onmiddellijke beëindiging van de relatie.

7. Toezicht, Handhaving en Jurisprudentie

Het toezicht is dual: de AP toetst op de AVG, terwijl de Inspectie Gezondheidszorg en Jeugd (IGJ) de informatiebeveiliging toetst als randvoorwaarde voor veilige zorg.

Organisatie | Boetebedrag | Kernovertreding | Geleerde Les || ----- | ----- | ----- | ----- ||

HagaZiekenhuis | €350.000,- | Gebrek aan MFA en logcontrole. | **Directe verbetering na incident verlaagt de boete.** || **OLVG** | €440.000,- | Onvoldoende MFA en logging. |

Technische basismiddelen zijn essentieel. || **CP&A** | €15.000,- | Registratie ziekteoorzaken. | **Dataminimalisatie: verwerk geen "nice-to-haves".** |

Critical Success Factors (CSF):

1. **Implementeer MFA:** Geen toegang tot medische data zonder meervoudige verificatie.
2. **Proactieve Logging:** Inclusief identiteit en tijdstempel voor volledige reconstructie.
3. **Technische isolatie:** Voorkom lokale opslag op mobiele devices.

8. Conclusie en Roadmap voor Implementatie

Informatiebeveiliging is de ruggengraat van patiëntenvertrouwen. Een integrale aanpak, waarbij IT-architectuur de juridische kaders dwingend volgt, is de enige weg naar compliance. **Stappenplan voor NEN 7510 Compliance:**

1. **Nulmeting & Transitie-scan:** Inventarisatie van huidige maatregelen en voorbereiding op de **nieuwe NEN 7510:2024 norm**.
2. **Risico-analyse:** Prioriteren van MFA-implementatie en uitfasering van onveilige BYOD-praktijken.
3. **Implementatie ISMS:** Inrichten van structurele processen voor logging en controle.
4. **Interne Audit:** Toetsing van de effectiviteit van de technische maatregelen (o.a. FLAG_SECURE checks).
5. **Certificering & Transitie:** Volledige certificering tegen de 2024-norm vóór de deadline van **20 februari 2027**. Beveiliging is geen rem op de zorg, maar de voorwaarde voor het veilig kunnen verlenen daarvan.